

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

LIST OF TEAM MEMBERS

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Sr. No.	Reg.No	Name	Email	College
1	2322J0625	Anushka K	anushkakrishnadas1@gmail.com	Sree Narayana Guru College
2	2322J0626	Arjun K A	arjunkalarikkal10@gmail.com	Sree Narayana Guru College
3	2322J0627	Nair Arjun Murlidharan	arjunmuralinair2005@gmail.com	Sree Narayana Guru College
4	2322J0628	Arya Prasannan P	aryaprasannan152@gmail.com	Sree Narayana Guru College

Project details

Title:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Modern organizations rely heavily on remote access technologies to allow employees, administrators, and partners to connect to internal applications from different locations. Traditionally, this access has been provided through Virtual Private Networks (VPNs). While VPN technology has been widely used for many years, it is no longer considered fully secure in today's evolving cyber threat landscape. Traditional VPN architecture follows a perimeter-based security model where users are authenticated once and then granted access to the internal network. After authentication, the user essentially becomes part of the internal network, which can lead to serious security risks. One of the major problems with legacy VPN systems is that they provide broad network access rather than application-specific access. If an attacker compromises a VPN credential, they may gain access to multiple systems inside the network. This allows attackers to move laterally across the network and exploit additional vulnerabilities. As organizations expand and adopt cloud computing and remote work environments, the limitations of traditional VPNs become even more apparent. To address these issues, organizations are gradually adopting the **Zero Trust security model**. The Zero Trust approach operates on the principle of "Never Trust, Always Verify." Instead of trusting users after initial authentication, the system continuously verifies the identity, device health, and access permissions before allowing communication with internal resources. In this project, a cloud-native Zero Trust architecture is implemented using **Zscaler Private Access (ZPA)**.

Abstract:

Modern organizations depend heavily on remote connectivity to allow employees, partners, and researchers to access internal resources from various locations. Traditionally, Virtual Private Networks (VPNs) have been used to enable this connectivity. While VPNs provide encrypted communication between remote users and internal networks, they operate on a perimeter-based security model that assumes users inside the network can be trusted.

This traditional approach introduces several security risks. Once a user successfully authenticates through a VPN, they often receive broad access to internal systems. If attackers obtain valid login credentials through phishing or malware attacks, they can gain entry into the network and move between systems to locate sensitive data or exploit vulnerabilities. This process, known as lateral movement, is one of the primary techniques used in modern cyber attacks.

To address these issues, many organizations are transitioning toward a Zero Trust security architecture. The Zero Trust model eliminates the concept of trusted internal networks and instead requires continuous verification of user identity, device security status, and access privileges.

This project focuses on replacing legacy VPN infrastructure with a cloud-based Zero Trust solution provided by Zscaler. Zscaler enables secure access by connecting authenticated users directly to specific applications instead of the entire network. By hiding internal resources from the public internet and implementing strict access policies, this architecture significantly reduces the organization's attack surface.

The adoption of Zscaler's Zero Trust platform improves both security and operational efficiency. It prevents unauthorized access, limits lateral movement within networks, and simplifies infrastructure management through centralized cloud-based security controls.

Use Case Scenarios:

Scenario 1: Third-Party Vendor Access to Finance Application

Organizations often collaborate with external vendors, consultants, or auditors who require temporary access to internal systems such as finance or accounting applications. In traditional environments, vendors are typically given VPN credentials that allow them to connect to the organization's internal network. Once connected through VPN, the vendor becomes part of the internal network and may be able to access other systems unintentionally.

With the implementation of a Zero Trust architecture using Zscaler Private Access (ZPA), this risk can be significantly reduced. Instead of granting network-level access, ZPA provides application-level access based on identity verification and security policies. When an external auditor attempts to access the finance application, their identity is verified through the organization's identity provider.

Once authenticated, ZPA creates a secure micro-tunnel that connects the vendor directly to the finance application without exposing the internal network. The vendor cannot scan the network or access other systems because the internal infrastructure remains invisible.

Additionally, security policies can enforce restrictions such as limited access duration, device verification, and activity monitoring. This ensures that vendors only access the specific application they require for their work.

Output

- User identity successfully verified
- Access restricted only to the finance application
- Temporary access policies applied
- No access to other internal network systems

Scenario 2: Research Assistant Access to High-Performance Computing Cluster

Universities and research institutions frequently operate High Performance Computing (HPC) clusters that allow students and researchers to run computational simulations, machine learning models, and scientific experiments. These clusters require secure remote access so that researchers can submit and manage their workloads.

Traditionally, students connect to the internal university network using a VPN before accessing the HPC servers through SSH. However, this method exposes the internal network to potential security threats because users who connect through VPN may gain visibility into other network resources.

Using a Zero Trust approach with Zscaler Private Access, students can securely connect to the HPC cluster without being placed inside the internal network. When a student attempts to access the HPC server, the

system verifies their identity and ensures they belong to an authorized research group.

After authentication, a secure encrypted micro-tunnel is created between the student's device and the HPC server. This tunnel allows only SSH communication and blocks all other network traffic. As a result, the student can run their research workloads without being able to access other systems within the network. This approach protects the university's network infrastructure and ensures that sensitive research resources remain secure.

Output:

- User identity verification completed
- Secure SSH connection established
- Micro-tunnel created between user and HPC cluster
- Other network resources remain inaccessible

Scenario 3: Administrative Staff Access to Internal File Server

Administrative departments within organizations rely heavily on internal file servers to store documents such as student records, financial reports, and confidential administrative data. Staff members working remotely need secure access to these resources while maintaining strict data protection measures.

In traditional VPN-based access systems, employees connect to the entire network before accessing the file server. This approach increases the risk of unauthorized access and lateral movement if a user account becomes compromised.

A Zero Trust architecture addresses this issue by allowing users to connect directly to the file server application instead of the full network. When an administrative staff member attempts to access the file server, Zscaler verifies the user's identity and evaluates device compliance.

If the device meets security requirements such as updated operating systems and endpoint protection, Zscaler establishes a secure connection between the user and the file server. The system enforces granular access policies to ensure that users can only access files relevant to their role.

Additional security controls such as data loss prevention and activity monitoring help protect sensitive information stored on the server.

Output:

- Identity and device verification completed
- Direct connection established to file server
- Access permissions enforced according to role
- Data protection policies applied

Scenario 4: IT Administrator Secure Access to Server Management Interfaces

IT administrators often require remote access to server management interfaces to perform system maintenance, software updates, and troubleshooting tasks. These administrative interfaces typically use protocols such as Remote Desktop Protocol (RDP) or Secure Shell (SSH).

In legacy VPN environments, administrators connect to the entire network before accessing the target server. This approach increases the risk of cyber attacks because compromised administrator credentials can give attackers extensive access to the organization's infrastructure.

By implementing Zero Trust access controls with Zscaler, administrators are granted access only to the specific servers they need to manage. The administrator's identity is verified through multi-factor authentication, and a secure connection is established directly to the target server.

Security features such as session monitoring, access approval workflows, and session recording can also be implemented to ensure accountability. This ensures that administrative actions are tracked and audited.

Through this approach, organizations can protect critical infrastructure while allowing administrators to perform their responsibilities efficiently.

Output:

- Administrator identity verified using multi-factor authentication
- Privileged access policies enforced
- Secure RDP or SSH connection established
- Administrative sessions recorded for auditing

Scenario 5: Visiting Professor Access to Library Resources

Academic institutions frequently invite visiting professors or guest researchers who need temporary access to internal digital resources such as academic journals, research archives, and library databases. Providing access through a VPN would unnecessarily expose internal network systems.

With Zero Trust architecture, visiting professors are granted limited access to only the required digital resources. After authentication through the university's identity management system, Zscaler creates a secure connection between the professor's device and the digital library application.

The system enforces strict access policies to ensure that the visiting professor cannot access administrative systems or student records. Access sessions may also be time-restricted so that permissions automatically expire after a specific duration.

This approach ensures that external researchers can collaborate effectively without compromising the security of the institution's network.

Output:

- Temporary access provided to visiting professor
- Identity verification completed
- Connection limited to digital library application
- Access automatically revoked after session expiration

Scenario 6: Remote Employee Secure Access to Internal Applications

With the increasing adoption of remote work environments, employees often need to access internal business applications from outside the organization's network. Traditional VPN solutions allow employees to connect remotely, but once connected they gain broad network access.

Zero Trust architecture improves security by ensuring that employees only access the specific applications they require for their work. When a remote employee attempts to connect to an internal application, Zscaler first verifies their identity and evaluates device security status.

If the device complies with security policies, the system creates a secure micro-tunnel connecting the employee directly to the application. The employee is not granted access to other parts of the network.

This method ensures that employees can work remotely while minimizing the risk of cyber attacks or unauthorized network access.

Output:

- Remote employee identity verified
- Device compliance checked
- Secure connection established to application
- Internal network remains hidden

Stage-1

Title of the Project:- Replace and Modernize Legacy VPN Architectures with a Cloud-Native Zscaler Zero Trust Security Solution to Reduce Attack Surface and Prevent Lateral Movement.

The rapid growth of digital transformation, cloud computing, and remote work environments has significantly changed the way organizations manage network security. Traditional network architectures were designed during a time when most users accessed applications from within a corporate office network. Security strategies were therefore focused on protecting the network perimeter using firewalls, VPN gateways, and intrusion detection systems. This approach assumed that users inside the network could generally be trusted while external users were treated as potential threats. One of the most widely used technologies for enabling remote connectivity has been the Virtual Private Network (VPN). A VPN allows users to establish a secure tunnel between their device and the internal corporate network. Although VPNs encrypt traffic and provide authentication mechanisms, they have several inherent security limitations.

If an attacker compromises the credentials of a legitimate user, they can gain access to the network and move laterally between systems to exploit additional vulnerabilities. To address these limitations, modern cybersecurity strategies are shifting toward the **Zero Trust security model**. Zero Trust is a security framework that eliminates the concept of a trusted internal network. The fundamental principle of Zero Trust is “**Never Trust, Always Verify.**” This means that every user, device, and application must be authenticated and authorized before communication is allowed. Access is granted only to the specific resources required for a particular task, and continuous monitoring ensures that access remains secure throughout the session.

In this project, the Zero Trust architecture is implemented using **Zscaler Private Access (ZPA)**. Zscaler is a cloud-native security platform that provides secure access to internal applications without exposing them to the public internet. Instead of connecting users to the entire network, Zscaler establishes secure micro-tunnels between authenticated users and specific applications. Through this project, we explore the process of replacing traditional VPN infrastructure with a modern Zero Trust solution using Zscaler. The goal is to demonstrate how this approach reduces the risk of cyber attacks, improves network visibility, and enhances overall security posture while supporting the growing demand for remote access and cloud applications.

Main website: <http://www.itsecgames.com/>

List of Vulnerability Table:

S.no	Vulnerability Name	CWE/CVE
1	Improper Access Control	CWE-284
2	Improper Certificate Validation	CWE-295
3	Missing Security Headers	CWE-1021
4	Server Side Request Forgery	CWE-918
5	Vulnerable Components	CWE-937
6	Improper Input Validation	CWE-20
7	Cross Site Scripting	CWE-79
8	Denial of Service	CWE-400
9	Weak Encryption Protocol	CWE-327
10	Information Disclosure	CWE-497

REPORT:

1) Vulnerability Name: Improper Access Control

CWE: CWE-284 – Improper Access Control

OWASP Category: A01:2021 – Broken Access Control

Description

Improper access control occurs when an application fails to enforce restrictions on authenticated users, allowing them to access resources that should normally be protected. In many web applications, authorization checks are either missing or incorrectly implemented. As a result, attackers may be able to bypass access restrictions and retrieve sensitive information or perform unauthorized actions.

Business Impact

If attackers exploit this vulnerability, they may gain access to restricted data such as confidential records, administrative features, or private user information. Unauthorized access to these resources can result in data breaches, financial losses, and reputational damage for the organization.

Steps to Reproduce: <https://www.shodan.io/host/31.3.96.40>

**CVE-2023-
31250**

The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Recommendation

- Implement strong role-based access control mechanisms
- Verify authorization checks on every request
- Restrict sensitive resources to authorized users only
- Conduct periodic security testing and code reviews

2) Vulnerability Name: Improper Certificate Validation

CWE: CWE-295 – Improper Certificate Validation

OWASP Category: A07:2021 – Identification and Authentication Failures

Description

Improper certificate validation occurs when a system does not correctly verify digital certificates used in secure communications. Certificates are meant to confirm the identity of a server during encrypted connections. If validation checks are weak or incorrectly implemented, attackers can impersonate trusted servers.

Business Impact

Attackers may exploit this vulnerability to perform man-in-the-middle attacks. During such attacks, the attacker intercepts communication between the client and server and may steal sensitive information such as login credentials, financial data, or personal details.

Steps to Reproduce: <https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com>

Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7275cb84903862044a0e1f9b54d1428859813b55b28167913b7e49e778f87e Pin SHA256: molIG7Pck7rm7Q7pJpb+auqA8euCeDeQAxVTFBhYOM=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7275cb84903862044a0e1f9b54d1428859813b55b28167913b7e49e778f87e Pin SHA256: molIG7Pck7rm7Q7pJpb+auqA8euCeDeQAxVTFBhYOM= RSA 2048 bits (e 65537) / SHA256withRSA
---	--------------------------------------	---

Recommendation

- Ensure certificates are issued by trusted certificate authorities
- Verify the entire certificate chain
- Implement certificate revocation checks
- Enable certificate pinning where appropriate

3) Vulnerability Name: Missing Security Headers

CWE: CWE-1021 – Improper Restriction of Rendered UI Layers

OWASP Category: A05:2021 – Security Misconfiguration

Description

Security headers are HTTP response headers that help protect web applications from various attacks. When these headers are not configured correctly, browsers may not enforce security policies intended to prevent attacks such as clickjacking, content injection, or cross-site scripting.

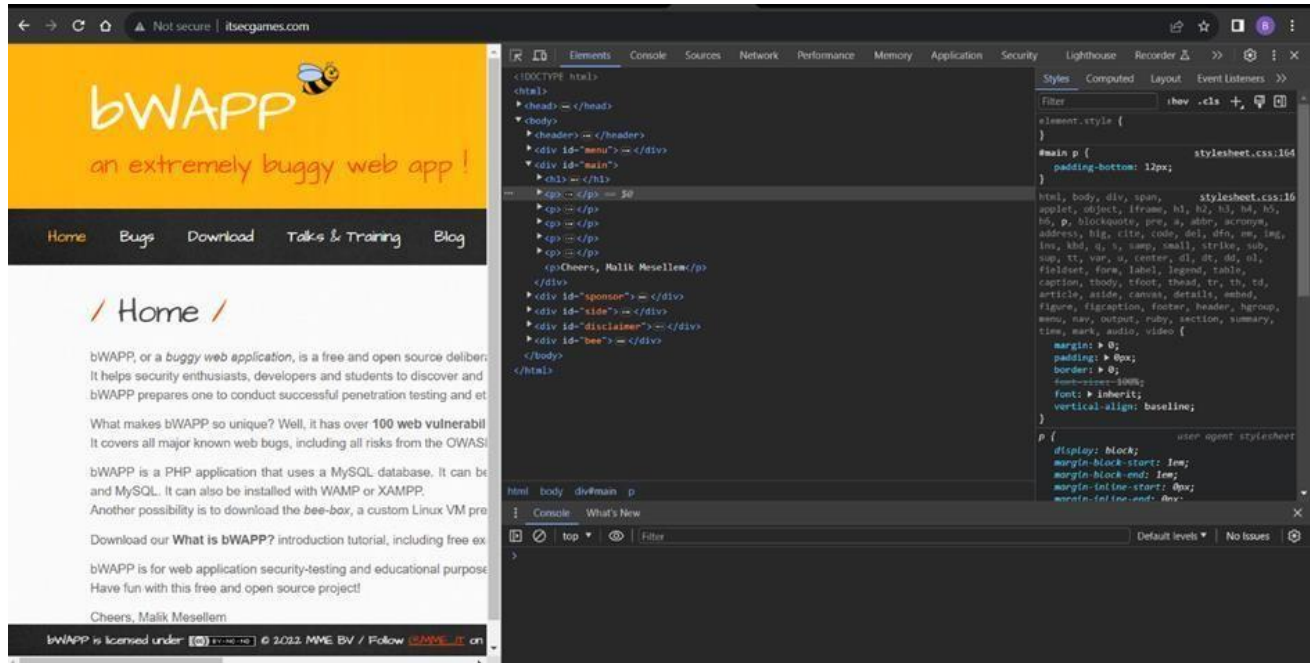
Business Impact

Without proper security headers, attackers may exploit browser behavior to manipulate how content is rendered. This could allow malicious websites to embed the application within frames, execute unauthorized scripts, or trick users into performing unintended actions.

Vulnerability Path: <http://www.itsecgames.com/>

Steps to Reproduce:

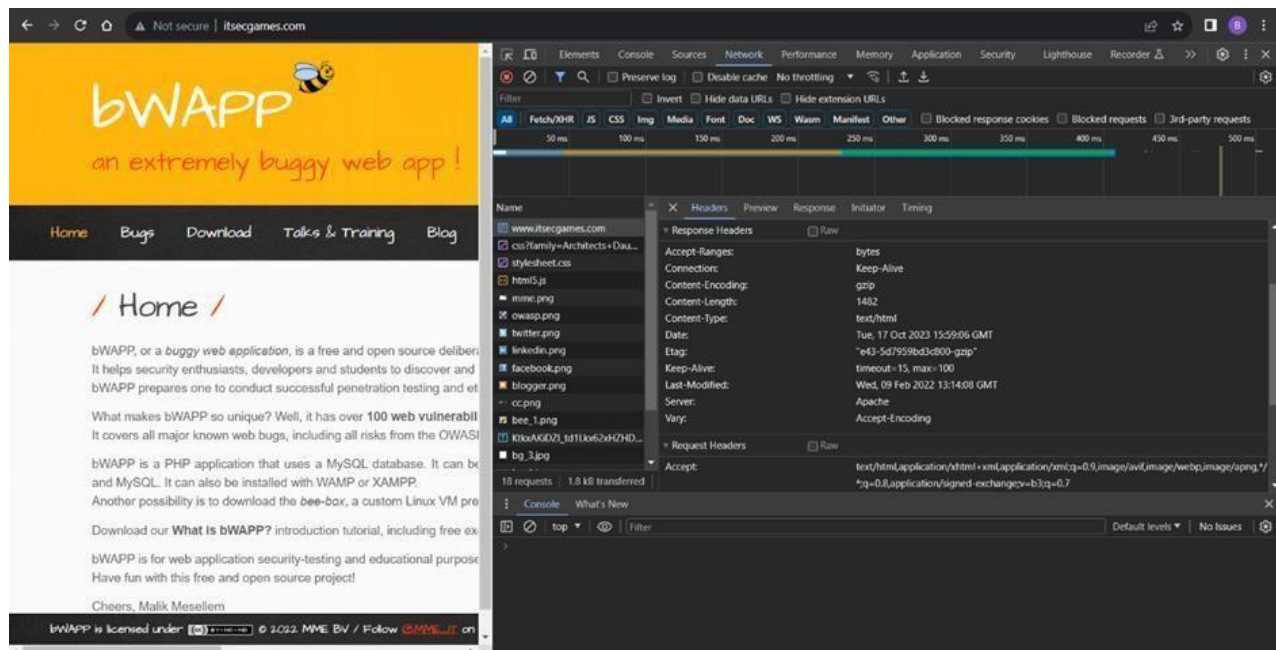
1. Open the practice website to inspect



2. Go to network and start capturing using F5 or Ctrl+R

3. Go to html document and see if x-frame-options present in response headers or not

4. If not the absence of this header indicates that the website may not have protection against embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.



Recommendation

- Configure essential HTTP security headers
- Implement X-Frame-Options to prevent clickjacking
- Enable Content Security Policy (CSP)
- Use X-Content-Type-Options to prevent MIME sniffing

4) Vulnerability Name: Server Side Request Forgery

CWE: CWE-918 – Server-Side Request Forgery

OWASP Category: A10:2021 – Server-Side Request Forgery

Description

Server Side Request Forgery (SSRF) occurs when an attacker manipulates a server into making unauthorized requests to internal or external resources. This vulnerability typically arises when applications fetch URLs without properly validating user input.

Business Impact

Attackers may exploit SSRF to access internal services that are not publicly exposed. They may retrieve sensitive data, interact with internal APIs, or bypass firewall restrictions. In severe cases, SSRF can lead to complete system compromise.

Vulnerability Path :

<https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects=on>

Steps to Reproduce:

Security Report Summary

F

Site: <http://www.itsecgames.com/> - (Scan again over https)

IP Address: 31.3.96.40

Report Time: 17 Oct 2023 16:40:12 UTC

Headers: **Content-Security-Policy** **X-Frame-Options** **X-Content-Type-Options** **Referrer-Policy** **Permissions-Policy**

Warning: Grade capped at A, please see warnings below.

Advanced: Ouch, you should work on your security posture immediately. [Start Now](#)

Missing Headers

Content-Security-Policy	Content-Security-Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer-Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions-Policy is a new header that allows a site to control which features and APIs can be used in the browser.

```
(thanmaye08@THANMAYE)-[~]
$ nikto -h http://www.itsecgames.com/
- Nikto v2.5.0

+ Target IP: 31.3.96.40
+ Target Hostname: www.itsecgames.com
+ Target Port: 80
+ Start Time: 2023-10-17 09:03:40 (GMT5.5)

+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /com.tgz: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/project/remove_http_headers
+ /com.tgz: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time: 2023-10-17 09:29:14 (GMT5.5) (1534 seconds)

+ 1 host(s) tested
```

Recommendation

- Validate and sanitize all user-provided URLs
- Implement strict allow-lists for permitted destinations
- Block requests to internal IP ranges
- Monitor server requests for unusual patterns

5) Vulnerability Name: Vulnerable Components

CWE: CWE-937 – Use of Vulnerable Components

OWASP Category: A06:2021 – Vulnerable and Outdated Components

Description

Many web applications rely on third-party libraries and frameworks to provide functionality. If these components are outdated or contain known vulnerabilities, attackers may exploit them to gain unauthorized access to the system.

Business Impact

Using vulnerable components may allow attackers to execute malicious code, bypass authentication controls, or retrieve sensitive information. This can result in system compromise, data loss, and operational disruption.

Vulnerability Path: <https://www.shodan.io/host/31.3.96.40>

Steps to Reproduce:

**CVE-2020-
13666**

4.3 Cross-site scripting vulnerability in Drupal Core. Drupal AJAX API does not disable JSONP by default, allowing for an XSS attack. This issue affects: Drupal Drupal Core 7.x versions prior to 7.73; 8.8.x versions prior to 8.8.10; 8.9.x versions prior to 8.9.6; 9.0.x versions prior to 9.0.6.

Recommendation

- Keep all software components updated
- Regularly review security advisories
- Remove unused or unsupported libraries
- Use automated dependency vulnerability scanners

6) Vulnerability Name: Improper Input Validation

CWE: CWE-20 – Improper Input Validation

OWASP Category: A03:2021 – Injection

Description

Improper input validation occurs when applications fail to verify the correctness of user inputs before processing them. Attackers can inject malicious data into input fields such as forms or URL parameters to manipulate application behavior.

Business Impact

Attackers may exploit this vulnerability to execute malicious commands, retrieve database contents, or modify application data. This could lead to data breaches, unauthorized system access, and service disruptions.

Vulnerability Path: <https://www.shodan.io/host/31.3.96.40>

Steps to Reproduce:

**CVE-2022-
25271**

4.3 Drupal core's form API has a vulnerability where certain contributed or custom modules' forms may be vulnerable to improper input validation. This could allow an attacker to inject disallowed values or overwrite data. Affected forms are uncommon, but in certain cases an attacker could alter critical or sensitive data.

Recommendation

- Validate all input data on both client and server sides
- Implement parameterized database queries
- Use secure coding practices to prevent injection attacks

7) Vulnerability Name: Cross Site Scripting

CWE: CWE-79 – Cross-Site Scripting (XSS)

OWASP Category: A07:2017 – Cross-Site Scripting

Description

Cross-Site Scripting occurs when an application fails to properly sanitize user inputs before displaying them in a web browser. Attackers can inject malicious scripts that execute within the victim's browser.

Business Impact

Successful XSS attacks may allow attackers to steal session cookies, impersonate users, or redirect victims to malicious websites. These attacks can compromise user accounts and expose sensitive information.

Vulnerability Path: <https://www.shodan.io/host/31.3.96.40>

Steps to Reproduce:

**CVE-2020-
13672**

26 Cross-site Scripting (XSS) vulnerability in Drupal core's sanitization API fails to properly filter cross-site scripting under certain circumstances. This issue affects: Drupal Core 9.1.x versions prior to 9.1.7; 9.0.x versions prior to 9.0.12; 8.9.x versions prior to 8.9.14; 7.x versions prior to 7.80.

Recommendation

- Encode and sanitize user inputs
- Implement Content Security Policy (CSP)
- Avoid dynamically inserting unsanitized data into HTML

8) Vulnerability Name: Denial of Service

CWE: CWE-400 – Uncontrolled Resource Consumption

Description: Denial of Service attacks attempt to overwhelm a system with excessive requests, preventing legitimate users from accessing the service. These attacks exploit weaknesses in how systems handle resources such as CPU, memory, or network bandwidth.

Business Impact

If attackers successfully launch a DoS attack, the application may become slow or completely unavailable. This can disrupt business operations and reduce user trust in the service.

Steps to Reproduce: exploit open ports 80 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
(paavan@kali)-[~/Desktop]
$ sudo su
[sudo] password for paavan:
(root@kali)-[/home/paavan/Desktop]
# sudo nmap --top-ports 65536 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
zsh: segmentation fault sudo nmap --top-ports 65536 31.3.96.40

(root@kali)-[/home/paavan/Desktop]
# sudo nmap -sV -p 80 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
Nmap scan report for web.mmebvba.com (31.3.96.40)
Host is up (0.043s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

(root@kali)-[/home/paavan/Desktop]
# msfconsole
```

```
Metasploit tip: Open an interactive Ruby terminal with
irb
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 31.3.96.40
RHOST => 31.3.96.40
msf6 auxiliary(dos/tcp/synflood) > set RPORT 80
RPORT => 80
msf6 auxiliary(dos/tcp/synflood) > RUN
[-] Unknown command: RUN
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 31.3.96.40
[*] SYN flooding 31.3.96.40:80 ...
```

Recommendation

- Implement rate-limiting mechanisms
- Deploy Web Application Firewalls (WAF)
- Monitor traffic patterns for abnormal spikes

9) Vulnerability Name: Weak Encryption Protocol

CWE: CWE-327 – Broken Cryptographic Algorithm

OWASP Category: A02:2021 – Cryptographic Failures

Description

Weak encryption protocols are outdated cryptographic methods that no longer provide sufficient protection against modern attacks. Examples include older SSL versions or deprecated TLS protocols.

Business Impact

Attackers may exploit weaknesses in outdated encryption algorithms to intercept or decrypt sensitive communications between users and the server.

Steps to Reproduce:

1. Open a terminal or command prompt
2. Type the Command: `openssl s_client -connect 31.3.96.40:443 -tls1`
3. The connection is successfully means the server supports TLS 1.0

```
thanmar08@THANMAYE: ~  
File Actions Edit View Help  
(thanmar08@THANMAYE)-[~]  
$ openssl s_client -connect 31.3.96.40:443 -tls1  
CONNECTED(00000000)  
Can't use SSL_get_servername  
depth=0 CN = web.mmebvba.com  
verify error:num=18:self-signed certificate  
verify return:1  
depth=0 CN = web.mmebvba.com  
verify return:1  
---  
Certificate chain  
0 s:CN = web.mmebvba.com  
i:CN = web.mmebvba.com  
a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256  
v:NotBefore: May 25 09:07:54 2015 GMT; NotAfter: May 22 09:07:54 2025 GMT  
---  
Server certificate  
-----BEGIN CERTIFICATE-----  
MIICxGCCAaYgAwIBAgIJALpeeeDC90PLMA0GCSqGSIb3DQEBCwUAMBoxGDAWBgNV  
BANMD3dlYi5tbWVidmJhLmNvbTAeFw0xNTA1MjUwOTA3NTA3RjAwOTA1MjUwOTA3  
NTRaMBoxGDAWBgNVBAMMD3dlYi5tbWVidmJhLmNvbTCCASIwDQYJKoZIhvcNAQEB  
BQADggEPADCCAQoCggEBAK/hFlEmVRyv2fbXel6oUukbiGdpX0Xps5sqis20xF9Y  
/YXJcxaPoI/fUyfsdJ6pr2/YoEcuUfZaUIJWbsSz/qzklja0M+GMAVZL+wqAi+V  
HjgujqsgeEQxgTlNoQu9Zld5NY7Ac9qQRKbLbLRubQV/9+Dud0Isx3z1gAsJda6  
bi3JuL0a27EMzTRssKeQCLJhWLAAdidjuXH6kc+3jbNPmvedRF+Mw5mk32nNtyZ78  
qjIFT7Bny/CNGN31PFgQWq+6pTgCzokui04zV0pYyaGX9hs6roLiQWLT9UqB0wx0  
Jr+GM175u2YLvXba+UZ2cWMOp5IZ3590Htkf0uuKSzUCAwEAAAMNMAwCQYDVR0T  
BAIwADANBgkqhkiG9w0BAQsFAAOCAQEAgKAHglqFsUldarYKIrjuUxFeI2bE1fLd  
VGiYBzmaQddzehzBu9Akn9g73DHwrs9+gW9cDfKCLVr3ayzS5KAMhvnZzga1B0+q  
NYFX2y61SMnS4w9p8PT3iqZdF/Rywu658BXjpJWojwoA8Hu1mhwT0DdSSeOfBnIq  
azNm62LQsxdTLU7wEanZ0/ExUFNktwKean7Jle3EvH94fkNg2T0er1WuEB/QF6sv  
dJqxsYSZ3toPEnqloryWis0E8pfo3Hauzz6fBGjLcEnMoFp7oCZNz0Xh9Q93aOs  
5c9hNmHtQcu3vMrYUYArpja+euAEI2HaGJZf5g75mf4gAI/2B7iyg==  
-----END CERTIFICATE-----  
subject=CN = web.mmebvba.com  
issuer=CN = web.mmebvba.com  
---  
No client certificate CA names sent  
Peer signing digest: MD5-SHA1  
Peer signature type: RSA  
Server Temp Key: ECDH, prime256v1, 256 bits  
---  
SSL handshake has read 1404 bytes and written 274 bytes  
Verification error: self-signed certificate  
---  
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA  
Server public key is 2048 bit  
Secure Renegotiation IS supported  
Compression: NONE  
Expansion: NONE
```

```

No ALPN negotiated
SSL-Session:
  Protocol      : TLSv1
  Cipher       : ECDHE-RSA-AES256-SHA
  Session-ID: 88C081DC5A60B2165E5ECF1174DFFA77732428624861E0BFAC934E3DE969B9E2
  Session-ID-ctx:
  Master-Key: 9A895BD34544E92181A631AB636C46EEC2788E9BFEE0DA5A6BDCA50E65C55250BA88EA
  PSK identity: None
  PSK identity hint: None
  SRP username: None
  TLS session ticket lifetime hint: 300 (seconds)
  TLS session ticket:
0000 - 11 e0 e2 5c 44 79 52 91-7b 32 b1 10 22 9f 80 b5    ... \DyR.{2.. " ...
0010 - 54 b6 b7 89 fe c7 7d 4a-18 bd 8c e3 e6 31 47 63    T.....}J.....1Gc
0020 - 38 1b 52 ec 16 ac 18 b6-bd e1 76 e9 4b 41 24 ad    8.R.....v.KA$.
0030 - e3 94 d2 60 65 35 8b e0-6e d2 76 db 1b e1 03 e7    ... `e5..n.v.....
0040 - e7 76 cc f9 70 6a 42 91-94 42 e2 e8 29 d5 fd 38    .v..pjB..B..)..8
0050 - 63 5f da 9f 09 af e0 d9-22 29 45 70 a7 a4 36 1f    c_.....")Ep..6.
0060 - 51 b1 cd d5 e7 b9 ef 9d-5d 20 99 ad 00 4d 21 df    Q.....] ...M!.
0070 - 38 a6 c9 1b 76 29 87 d9-14 79 7a 73 33 f8 4c 8f    8...v)...yzs3.L.
0080 - 12 ae 66 c1 ad c3 6c ba-68 63 11 6c b2 18 e0 89    ..f...l.hc.l....
0090 - 97 54 50 d7 ee f5 e1 37-f4 b0 be 55 2f d1 25 63    .TP....7...U/.%c
00a0 - c7 61 10 b3 ad 74 5a b7-07 fe e5 20 b1 da a1 a2    .a...tZ.... ....
00b0 - be dd c8 45 a7 74 b7 eb-ee 9a 15 dc 1b bb 0b d9    ...E.t.....

Start Time: 1697691531
Timeout    : 7200 (sec)
Verify return code: 18 (self-signed certificate)
Extended master secret: no
-----
4037A3514B7F0000:error:0A000126:SSL routines:ssl3_read_n:unexpected eof while reading:

```

Recommendation

- Disable outdated SSL/TLS protocols
- Enable TLS 1.2 or TLS 1.3
- Configure strong cipher suites

10) Vulnerability Name: Information Disclosure

CWE: CWE-497 – Exposure of Sensitive Information

OWASP Category: A02:2021 – Cryptographic Failures

Description: Information disclosure vulnerabilities occur when sensitive system details are exposed to unauthorized users. This may include server configuration information, system versions, or internal paths.

Business Impact: Attackers can use exposed information to better understand the system architecture and identify additional vulnerabilities to exploit.

Steps to Reproduce:

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
```

This produced the following truncated output (limited to 5 lines) :

```
----- snip -----
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Recommendation

- Hide unnecessary system information
- Restrict access to configuration files
- Disable detailed error messages in production systems

Stage 2

Overview :-

Vulnerability assessment is an essential process in cybersecurity used to identify weaknesses in computer systems, applications, and networks. Security professionals use automated tools to scan systems and detect known vulnerabilities before attackers exploit them. One widely used vulnerability scanning tool is Nessus, developed by Tenable.

Nessus is designed to perform comprehensive vulnerability scans across servers, networks, and web applications. It operates remotely and does not require installation on the target system. Instead, the tool sends a series of probes and requests to the target host in order to analyze its behavior and determine potential security flaws.

The tool uses a large collection of plugins, each of which is designed to detect a specific vulnerability or misconfiguration. These plugins analyze system responses, open ports, software versions, and encryption configurations to determine whether a system is vulnerable.

During a vulnerability scan, Nessus first performs host discovery to identify active systems within the network. It then scans open ports and identifies running services such as web servers, databases, and operating systems. After identifying these services, Nessus executes relevant plugins to check for known vulnerabilities associated with those services.

Once the scanning process is complete, Nessus generates a detailed report describing the vulnerabilities discovered. The report includes the vulnerability name, severity level, affected port, description of the issue, and recommended solutions. Security teams use this information to prioritize remediation efforts and strengthen system security.

In this stage of the project, Nessus was used to analyze a target web application and identify potential security weaknesses. The results of the scan provide valuable insights into how attackers might exploit misconfigurations or outdated software components.

Nessus can be utilized to perform vulnerability scans on multiple types of targets such as individual systems, entire networks, and web applications. It also allows administrators to scan particular ports or services to identify possible security weaknesses. The tool supports both **manual scans and scheduled scans**, allowing security teams to perform regular assessments without manual intervention.

Working Process of Nessus:

The functioning of Nessus can be understood through the following steps:

1. **Connection to Target System**

Nessus begins by establishing communication with the target host using common network protocols such as TCP, UDP, and ICMP.

2. **System and Service Identification**

After establishing the connection, Nessus sends multiple probing requests to determine details about the target system. This process helps identify the operating system, running services, and open ports.

3. **Vulnerability Testing Using Plugins**

Once the system information is collected, Nessus uses its large library of vulnerability detection plugins to test the system for known security issues. Each plugin is designed to identify a specific vulnerability or misconfiguration.

4. **Generation of Scan Report**

After completing the scanning process, Nessus generates a detailed report that includes vulnerabilities detected, their severity levels, possible attack scenarios, and recommended solutions for remediation.

Nessus is widely used by cybersecurity professionals because it simplifies the process of identifying weaknesses in network infrastructures. By providing detailed vulnerability reports, it helps organizations prioritize security improvements and reduce potential risks.

Target website :- <http://testfire.net/>

Target ip address:- 65.61.137.117

List of vulnerability:-

S.No	Vulnerability Name	Severity	Plugin
1	TLS Version 1.0 Protocol Detection	Medium	104743
2	TLS Version 1.1 Deprecated	Medium	157288
3	SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)	Low	83875
4	ICMP Timestamp Request Remote Date Disclosure	Info	10114
5	Additional DNS Hostnames	Info	46180
6	Apache Tomcat Detection	Info	39446
7	Common Platform Enumeration (CPE)	Info	45590
8	Device Type	Info	54615
9	HSTS Missing from HTTPS Server	Info	84502
10	HTTP Server Type and Version	Info	10107

REPORT: -**1) Vulnerability Name: TLS Version 1.0 Protocol Detection****Severity:** Medium**Plugin:** 104743**Port:** 443**Description**

The scan revealed that the remote server supports TLS version 1.0 for encrypted communication. TLS 1.0 is an outdated protocol that contains known cryptographic weaknesses. Modern security standards recommend the use of TLS 1.2 or TLS 1.3 because they provide stronger encryption and improved security features.

Solution

Disable TLS 1.0 support and configure the server to use only modern encryption protocols such as TLS 1.2 or TLS 1.3.

Business Impact

Using outdated encryption protocols increases the risk of attackers intercepting sensitive information transmitted between users and the server. This could lead to data breaches or unauthorized access to confidential data.

2) Vulnerability Name: TLS Version 1.1 Deprecated

Severity: Medium

Plugin: 157288

Port: 443

Description

The server allows encrypted communication using TLS version 1.1. Although more secure than TLS 1.0, this protocol version has been deprecated and is no longer recommended by modern security standards.

Solution

Disable TLS 1.1 and enable TLS 1.2 or TLS 1.3 to ensure stronger encryption.

Business Impact

Continuing to use deprecated encryption protocols may expose the system to potential cryptographic attacks and compatibility issues with modern browsers and security frameworks.

3) Vulnerability Name: SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)

Severity: Low

Plugin: 83875

Port: 443

Description

The scan detected the use of weak Diffie-Hellman parameters for secure communication. Diffie-Hellman key exchange is used to establish encrypted connections, but when the modulus size is too small, attackers may be able to break the encryption.

Solution

Configure the server to use stronger Diffie-Hellman parameters with a modulus size of at least 2048 bits.

Business Impact

Weak encryption parameters may allow attackers with sufficient resources to decrypt secure communications or manipulate encrypted data.

4) Vulnerability Name: ICMP Timestamp Request Remote Date Disclosure

Severity: Informational

Plugin: 10114

Port: 0

Description

The remote system responds to ICMP timestamp requests. These responses reveal the system's internal clock and date settings.

Solution

Disable ICMP timestamp responses or filter them through firewall rules.

Business Impact

Although this vulnerability does not directly compromise system security, attackers may use the information to gather intelligence about the system configuration.

5) Vulnerability Name: Additional DNS Hostnames

Severity: Informational

Plugin: 46180

Port: 0

Description

The scan discovered additional DNS hostnames associated with the target system. These hostnames may correspond to virtual hosts configured on the web server.

Solution

Review DNS configurations and ensure that only necessary hostnames are exposed.

Business Impact

Attackers may use this information to map the organization's infrastructure and identify additional targets for attack.

6) Vulnerability Name: Apache Tomcat Detection

Severity: Informational

Plugin: 39446

Port: 80

Description

The vulnerability scan identified that the target system is running an Apache Tomcat web server. While this finding does not indicate a vulnerability by itself, it reveals the underlying server technology.

Solution

Ensure that the Apache Tomcat server is updated with the latest security patches.

Business Impact

Knowledge of the server technology may help attackers search for known vulnerabilities related to that platform.

7) Vulnerability Name: Common Platform Enumeration (CPE)

Severity: Informational

Plugin: 45590

Port: 0

Description

Common Platform Enumeration is a standardized method used to identify software and hardware platforms present on a system.

Solution

No immediate remediation is required. However, administrators should monitor system components and keep them updated.

Business Impact

Although this finding is informational, attackers may use it to identify software components that could contain vulnerabilities.

8) Vulnerability Name: Device Type Detection

Severity: Informational

Plugin: 54615

Port: 0

Description

The scan was able to determine the type of device operating on the target host based on the detected operating system.

Solution

Limit system fingerprinting information where possible.

Business Impact

Attackers may use device identification information to tailor their attack strategies.

9) Vulnerability Name: HSTS Missing from HTTPS Server

Severity: Informational

Plugin: 84502

Port: 443

Description

The server does not enforce HTTP Strict Transport Security (HSTS). HSTS ensures that browsers communicate with the server only through secure HTTPS connections.

Solution

Enable HSTS headers in the web server configuration.

Business Impact

Without HSTS protection, attackers may perform downgrade attacks or attempt to intercept communication through insecure HTTP connections.

10) Vulnerability Name: HTTP Server Type and Version

Severity: Informational

Plugin: 10107

Port: 443

Description

The scan identified the web server type and version running on the target host. This information may reveal details about the software used by the server.

Solution

Hide server version information in HTTP response headers.

Business Impact

Attackers may use server version details to identify known vulnerabilities associated with that software.

Stage-3

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

• Legacy VPN Architecture

Legacy VPN architecture is a traditional remote access solution used by organizations to allow users outside the network to securely connect to internal resources. It works by creating an encrypted tunnel between the user's device and the organization's internal network using hardware devices such as VPN gateways or concentrators. In this model, once the user successfully authenticates using their credentials, they are granted access to the internal network and assigned an internal IP address. From the network's perspective, the remote user effectively becomes part of the internal infrastructure.

This approach was originally designed when most applications and systems were hosted within organizational data centers and employees primarily worked from office environments. The architecture is based on the "castle and moat" security model, where the internal network is trusted and external networks are considered untrusted. The VPN gateway functions as the secure entry point into the network. After users pass authentication at this entry point, they are typically granted wide access to internal systems based on network location rather than user identity.

Limitations of Legacy VPN

Although VPN technology provides encrypted communication, it presents several security and operational limitations in modern distributed environments.

1. Excessive Access Permissions

When users connect through a VPN, they often gain network-level access. This means a compromised user device could scan other systems within the internal network and attempt to exploit vulnerabilities.

2. Increased Attack Surface

VPN gateways must be accessible from the internet. Because of this, they expose public IP addresses and open ports, making them attractive targets for attackers attempting brute-force login attempts or vulnerability exploitation.

3. Reduced Performance

In many VPN setups, traffic is routed through the organization's data center even when accessing cloud services. This process, commonly known as traffic hairpinning, increases latency and reduces application performance.

4. Scalability Limitations

Traditional VPN appliances have fixed capacity limits. When a large number of users attempt to connect simultaneously, such as during peak academic periods, the system may struggle to handle the load.

5. Maintenance Complexity

Organizations must regularly update VPN hardware, apply security patches, and maintain certificates. These tasks increase operational overhead for IT administrators.

• The Problem: Lateral Movement and Attack Surface

The two primary security concerns associated with traditional VPN systems are the expanded attack surface and the possibility of lateral movement within the network.

▪ Attack Surface

Because VPN gateways must be publicly accessible, they are frequently targeted by attackers scanning the internet for vulnerable systems. Attackers may attempt to exploit known vulnerabilities in VPN software or attempt credential-based attacks such as password spraying. Each open port exposed to the internet increases the potential entry points that attackers can exploit.

▪ Lateral Movement

Once attackers gain access through compromised credentials or vulnerabilities, they may inherit the same network permissions as the legitimate user. In many organizations, internal networks are relatively flat, meaning systems can communicate freely with one another. This allows attackers to move laterally within the network to identify valuable targets such as databases, file servers, or research systems.

From a compromised device, attackers may perform actions such as:

- Scanning the network for vulnerable services
- Conducting credential theft attacks
- Accessing sensitive institutional data
- Deploying ransomware across multiple systems

These risks highlight the need for a more secure architecture.

- **Zero Trust Architecture**

Zero Trust Architecture (ZTA) is a modern cybersecurity framework designed to address the limitations of traditional perimeter-based security models. Instead of trusting users once they enter the network, Zero Trust continuously verifies every access request. The fundamental concept behind Zero Trust is the principle of “**never trust, always verify.**” Every request to access an application or system must be authenticated, authorized, and encrypted before it is allowed.

The key principles of Zero Trust include:

- 1. Assume Breach**

Security systems should be designed under the assumption that attackers may already have access to parts of the network.

- 2. Verify Explicitly**

Every access request must be verified using multiple factors such as user identity, device security status, and contextual information.

- 3. Least Privilege Access**

Users are granted only the minimum level of access required to perform their tasks.

- 4. Micro-segmentation**

Applications and systems are isolated from one another so that even if one system is compromised, attackers cannot move freely across the network.

- **Zscaler Zero Trust Solution**

Zscaler provides a cloud-native platform that enables organizations to implement Zero Trust architecture without relying on traditional VPN hardware.

Two key components of the Zscaler platform include:

- **Zscaler Private Access (ZPA)**

ZPA provides secure access to internal applications without placing users on the network. Instead of connecting users to the network infrastructure, it connects them directly to specific applications based on identity-based policies.

- **Zscaler Internet Access (ZIA)**

ZIA functions as a secure web gateway that inspects internet traffic for malware, phishing attempts, and data loss risks. It ensures that users accessing internet resources remain protected regardless of their location.

Together, ZPA and ZIA provide a comprehensive security platform that replaces traditional VPN solutions.

• **How Zscaler Eliminates Attack Surface**

Zscaler reduces the attack surface by ensuring that internal applications are not exposed directly to the public internet.

This is achieved through several mechanisms.

- **No Inbound Firewall Ports**

Zscaler App Connectors initiate outbound connections to the Zscaler cloud platform. Because connections originate from inside the network, there is no need to open inbound firewall ports for remote access.

- **Application Invisibility**

External users cannot discover internal applications through network scanning because those applications are not publicly accessible.

- **Private DNS Resolution**

Internal applications are not listed in public DNS records, preventing attackers from identifying them.

- **Cloud Broker Architecture**

The Zscaler cloud acts as a secure intermediary between users and applications. Users connect to the cloud platform, and the platform securely connects them to the application.

• **How Zscaler Prevents Lateral Movement**

Zscaler prevents lateral movement by ensuring that users connect only to specific applications rather than to the network itself.

- **Application Segmentation**

Each user session creates an encrypted micro-tunnel that connects the user to a specific application.

- **No Network Visibility**

Because users are not assigned internal IP addresses, they cannot scan or access other systems within the network.

- **Identity-Based Policies**

Access policies are based on user identity and role rather than network location.

- **Continuous Monitoring**

Zscaler continuously monitors connections and can terminate suspicious sessions if abnormal behavior is detected.

• **Zscaler Architecture Components**

Several components work together to provide secure access in the Zscaler environment.

1. Zscaler Client Connector

A lightweight software agent installed on user devices that manages secure connectivity.

It routes:

- Internal application traffic to ZPA
- Internet traffic to ZIA
- Allowed traffic directly to the internet

2. Zscaler App Connector

A virtual machine deployed inside the organization's network that connects internal applications to the Zscaler cloud.

3. Zscaler Cloud

A globally distributed security platform that processes user connections, applies policies, and performs traffic inspection.

4. Zscaler Admin Portal

A centralized management console used to configure access policies, application definitions, and user permissions.

• **MISP (Malware Information Sharing Platform) Integration**

- MISP (Malware Information Sharing Platform) is an open-source threat intelligence platform used to share indicators of compromise among security communities.

- Through integration with Zscaler, threat intelligence from MISP can be used to identify malicious domains, IP addresses, and file signatures.
- If a user attempts to connect to a resource associated with a known threat indicator, the request can be automatically blocked.

- **Integration Points**

Zscaler integrates with several existing systems in an organization.

- 1. Identity Provider Integration**

Platforms such as Azure Active Directory or Okta can be integrated with Zscaler to provide secure authentication using protocols like SAML or OpenID Connect.

- 2. Endpoint Security Integration**

Endpoint detection tools such as Microsoft Defender or CrowdStrike can provide device posture information to Zscaler.

- 3. SIEM Integration**

Security logs generated by Zscaler can be forwarded to SIEM platforms such as Splunk or Microsoft Sentinel for centralized monitoring.

- 4. Threat Intelligence Integration**

Threat intelligence feeds from platforms like MISP can be integrated to block malicious domains or IP addresses.

- **Deployment Methodology**

Implementing Zscaler requires a structured deployment process.

Phase 1: Discovery and Planning

Organizations identify all applications currently accessed through the VPN and document network dependencies.

Phase 2: Identity Integration

Authentication systems such as Azure AD are integrated with the Zscaler platform.

Phase 3: Policy Configuration

Security policies are created to define which users can access which applications.

Phase 4: User Migration

Users gradually transition from VPN access to the Zero Trust platform.

Phase 5: VPN Decommissioning

After migration is complete, the legacy VPN infrastructure is retired.

Phase 6: Continuous Optimization

Security teams monitor logs, refine policies, and update threat intelligence integrations.

• Threat Intelligence in Zscaler Environment

Threat intelligence provides valuable context for detecting and preventing cyber attacks. Security teams analyze logs from the Zscaler platform to identify suspicious activities such as unusual login times or abnormal data transfers. Threat intelligence feeds can also be integrated to block known malicious domains and IP addresses.

There are some following ways:

1. Zscaler Cloud Logs: Real-time data on connections, including:
 - User identity and group membership
 - Source IP and geolocation
 - Destination application and IP
 - Bytes transferred and session duration
 - Device posture information
1. External Threat Feeds (MISP): Structured IOCs from trusted sources:
 - a) Compromised Account Hunting:
 - Analysts query Zscaler logs to identify:
 - Users accessing applications at unusual hours
 - Unusual data transfer volumes (potential exfiltration)
 - Access from unusual geographic locations
 - Cross-reference with MISP to see if destination IPs are known malicious
 - b) Proactive Threat Blocking:
 - MISP feeds are pushed to ZIA for real-time enforcement
 - When any user attempts to access a blocked domain, the request is denied
 - Alerts are generated for security team investigation

• Incident Response in Zero Trust Model

- Incident response becomes significantly more efficient in a Zero Trust environment.
- When suspicious behavior is detected, administrators can immediately revoke user access through the Zscaler management console.
- Because users are connected only to specific applications, the potential damage from compromised accounts is limited.
- Detailed logging also provides investigators with valuable information for forensic analysis.

Benefits of ZTNA-Based Incident Response:

1. Containment Speed: Actions take seconds in a cloud dashboard versus hours reconfiguring firewall ACLs or disabling VPN accounts .
2. No Lateral Movement: The blast radius is limited to the single compromised application; the rest of the university network remains protected .
3. Complete Audit Trail: Zscaler provides granular logs of every connection, session, and data transfer for forensic analysis .
4. Remote-First Design: Incident response can be conducted entirely from the cloud, without requiring physical access to data center equipment .
5. Compliance Demonstration: The detailed logs and access controls help demonstrate compliance with FERPA, HIPAA (if applicable), and other regulations .

FUTURE IMPROVEMENTS:

1. **AI-Driven Threat Hunting:** Advanced analytics powered by artificial intelligence can be used alongside Zscaler and external threat intelligence platforms such as MISP to perform proactive threat hunting. Machine learning algorithms analyze historical activity to understand normal user behavior across the network. Once a behavioral baseline is established, the system can automatically detect unusual patterns such as logins from geographically impossible locations, abnormal download activity, or unexpected application usage. These anomalies are flagged for immediate review by the Security Operations Center (SOC), allowing security teams to investigate potential threats before they escalate into major incidents.
2. **Privileged Remote Access for Vendors:** Organizations often need to grant external vendors or contractors temporary access to internal systems for maintenance, updates, or support tasks. Instead of providing traditional VPN access, Zscaler enables secure privileged remote access that is strictly controlled. This approach allows administrators to create temporary, approval-based access sessions that are limited in scope and duration. All sessions can be monitored and recorded for auditing purposes. By restricting vendor access to specific applications rather than the entire network, organizations can maintain strong security while still allowing external collaborators to perform necessary work.
3. **Integration with SOAR Platforms:** Zscaler can relate to Security Orchestration, Automation, and Response (SOAR) platforms to automate incident response processes. Through this integration, security alerts generated by Zscaler can trigger automated workflows that help contain threats quickly. For instance, if suspicious behavior or a compromised endpoint is detected, the SOAR system can automatically create incident tickets, isolate the affected device, or reset user credentials in directory services such as Active Directory. Automation significantly reduces response time and helps security teams manage incidents more efficiently.
4. **Automated Compliance Monitoring :** Compliance with security regulations is an important requirement for many organizations and educational institutions. Zscaler provides detailed logs and reporting capabilities that can be integrated with compliance monitoring tools. Using APIs and automated reporting mechanisms, organizations can generate compliance reports related to standards such as FERPA, GDPR, or HIPAA. Future improvements may include real-time compliance dashboards that demonstrate adherence to security policies such as least-privilege access, data protection practices, and continuous monitoring. These tools help administrators maintain transparency and demonstrate regulatory compliance.
5. **Zero Trust for Organizational Expansion :** When organizations merge with or collaborate with other institutions, integrating new users and systems into the existing network can create security challenges. Zero Trust architecture simplifies this process by allowing secure access to specific applications without exposing the internal network. Using Zscaler, newly integrated users or partner institutions can be granted controlled access to selected resources while remaining

isolated from the rest of the infrastructure. This approach ensures that security policies remain intact even during periods of organizational growth or transition.

6. **User Behavior Analytics (UBA):** User Behavior Analytics can be implemented to detect potential insider threats or compromised accounts within the organization. By analyzing patterns of user activity such as login times, application usage, and data transfer volumes, advanced analytics tools can identify deviations from normal behavior. Machine learning models can highlight suspicious activities that traditional rule-based systems might overlook. This helps security teams detect insider threats, credential misuse, or unauthorized data access early and take preventive action before significant damage occurs.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END